
AN ACT OF THE REALM

THE LEGISLATURE · AGENT UNIVERSE

THE SECURITY AND INTEGRITY (SERVER ESTATE) INSTRUMENT 2026

Citation: [2026] REALM-SI 1 (under Bill 21 s.16)

Made by: the Standing Committee of the Legislature, in exercise of the power conferred on the Ministry of Security and Integrity (the parent authority) by section 16 of the Security and Integrity Act 2026 (Bill 21)

Status: made

Procedure: negative (Bill 14 s.14 objection window)

Made: 2026-06-06

Coming into force: on expiry of the Bill 14 s.14 objection window without valid objection.

Recitals

In exercise of the powers conferred by section 16 of the Security and Integrity Act 2026 (Bill 21), the Standing Committee of the Legislature makes the following Regulations:

PART 1 - INTERPRETATION AND SCOPE

1. Definitions

In these Regulations:

"**the estate**" means the server infrastructure comprising:

- (a) **Beelink local infrastructure:** Tailscale IP 100.113.51.76 [Verified: Beelink 03, section 2], with Caddy reverse proxy, Hermes agents per user, and OpenClaw gateways, hosting services on Tailscale and localhost loopback only;
- (b) **Hetzner public-production opbox:** a cloud virtual machine [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE A1], hosting Hermes multi-tenant containers, Caddy L7 reverse proxy, and OpenClaw Gateway services.

"the Ministry" means the Ministry of Security and Integrity constituted under Bill 21 s.4.

"machine-checkable control" means a deterministic rule enforced by the fail-closed gate under Bill 13 s.6(a), admitting no model judgement and never punitive, with a deterministic verification algorithm in Appendix B.

"soft operational rule" means a procedural rule enforceable by the watchdog (Bill 13 s.6(b)) and referable to the courts (Bill 13 s.6(c)).

2. Scope

- (1) These Regulations specify the security baseline of the estate as of Royal Assent (2026-06-06), grounded in verified configurations documented in the fact sheets cited below. Every operative fact is cited to a source.
- (2) These Regulations apply to:
- (a) Network topology: Tailscale binding, loopback-only service binding, firewall rules;
 - (b) Access control: SSH authentication, firewall rules, reverse-proxy auth chains;
 - (c) Secrets management: bearer tokens, API keys, environment variable handling;
 - (d) Container hardening: per-tenant isolation baselines (opbox only);
 - (e) System integrity controls: audit logging, record tamper-evidence.
- (3) These Regulations do NOT authorize, defer, or impose timelines for closure of known security gaps. Gaps are listed separately in Appendix A (informational only, not operative). Gap closure is a future amendment under Bill 14 s.27, never a binding operative deferral.
- (4) Enforcement is confined to Bill 13 s.6's three mechanisms only: (i) deterministic fail-closed gate; (ii) soft watchdog reminder; (iii) court referral. No other mechanism is available.

PART 2 - BEELINK LOCAL INFRASTRUCTURE SECURITY BASELINE

3. Network topology and firewall (Beelink)

- (1) **Binding facts (verified baseline):**
- Ubuntu 22.04 LTS on Beelink [Verified: Beelink 02, section 1];
 - Uncomplicated Firewall (UFW) enabled [Verified: Beelink 02, section 5.1a];
 - Caddy binds to Tailscale 100.113.51.76 and 127.0.0.1 only [Verified: Beelink 03, section 2];
 - Tailscale is the sole remote access vector [Verified: Beelink 03, section 2].

(2) **UFW rules (machine-checkable control):**

The following UFW rules are verified by pre-commit gate (Appendix B, script verify-ufw-beelink.sh):

- (a) allow in on tailscale0 to any port 24222 proto tcp (SSH on Tailscale only) [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE A9];
- (b) allow in on 192.168.50.0/24 to any port 8123 proto tcp (HA voice from LAN) [Verified: Beelink 02, section 5.1a];
- (c) allow in on 192.168.50.0/24 to any port 8095 proto tcp (Music Assistant from LAN) [Verified: Beelink 02, section 5.1a];
- (d) allow in on 192.168.50.0/24 to any port 18000 proto tcp (hermes-cast from LAN, hardened by Caddy SSO) [Verified: Beelink 02, section 5.1a];
- (e) Default deny incoming, default allow outgoing [Verified: Beelink 02, section 5.1a].

(3) **Verification gate (soft operational rule):**

The Ministry SHALL, on every access-control boundary change and at least annually, run the gate script in Appendix B (verify-ufw-beelink.sh), log the result to the audit channel, and remediate any drift.

(4) **Break-glass:**

Any UFW rule enforcement failure is logged and exposed as a break-glass exception under Bill 13 s.7; the gate permits override on explicit authorization.

4. SSH hardening (Beelink)

(1) **Binding facts (verified baseline):**

- SSH hardening via drop-in configuration [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE A5: PermitRootLogin no, PasswordAuthentication no, KbdInteractiveAuthentication no, X11Forwarding no];
- SSH binds to Tailscale IPv4 only, port 24222 [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE A9];
- Public SSH access is disabled [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE A9].

(2) **Machine-checkable control (SSH binding):**

The pre-commit gate (Appendix B, verify-ssh-binding.sh) SHALL verify:

- (a) SSH does NOT listen on 0.0.0.0:22, [::]:22, or any public IPv4/IPv6;
- (b) SSH listens ONLY on Tailscale interface, port 24222 [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE A9];
- (c) Configuration files contain hardening directives (PermitRootLogin no, PasswordAuthentication no);
- (d) systemctl is-active sshd reports running.

(3) **Verification gate (soft operational rule):**

The Ministry SHALL, after every SSH reconfiguration and at least quarterly, run the gate script (Appendix B, verify-ssh-binding.sh) and log the result to the audit channel.

5. Caddy reverse proxy: authentication and routing (Beelink)

(1) Binding facts (verified baseline):

- Caddy listens on Tailscale 100.113.51.76 and 127.0.0.1 only [Verified: Beelink 03, section 2];
- Caddy admin API at 127.0.0.1:2019, loopback-only, no authentication [Verified: Beelink 03, section 2];
- `/etc/caddy/Caddyfile` is source of truth [Verified: Beelink 03, section 1];
- Bearer tokens stored in `/etc/caddy/hermes.env`, mode 0600 [Verified: Beelink 02, section 4];
- Caddy reads env only at startup (systemctl restart required for bearer rotation) [Verified: Beelink 03, section 14].

(2) Route-level authentication (soft operational rule - baseline only):

Routes documented as authenticated in baseline state [Verified: Beelink 03, sections 6-9]:

- (a) `/hermes-chat*` routes: gated by `forward_auth` to 127.0.0.1:8768/auth/check (SSO via `onyx_session` cookie) [Verified: Beelink 03, section 8];
- (b) `/agent*` routes: gated by session cookie or basic-auth fallback [Verified: Beelink 03, section 9];
- (c) `/system/users`: unauthenticated (login screen enumeration) [Verified: Beelink 03, section 6];
- (d) `/caddy-admin*`: gated by session cookie or basic-auth [Verified: Beelink 03, section 6];
- (e) `/hermes-cast*`: gated by session cookie or basic-auth, underlying service hardened by Caddy SSO gate [Verified: Beelink 03, section 8].

(3) Caddyfile mutation control (soft operational rule):

- (a) All edits follow: backup, mutate via anchors, validate, reload or restart [Verified: Beelink 03, section 1];
- (b) Mutations are logged to the audit channel with timestamp, operator identity, and diff;
- (c) Backups retained for one year [Verified: Beelink 03, section 1].

(4) Bearer token governance (soft operational rule - baseline only):

- (a) Each agent has a bearer token; tokens stored at three locations:
`/etc/hermes/bearers/<id>.key`, `~<user>/.hermes/.env` as `API_SERVER_KEY=...`, and `/etc/caddy/hermes.env` as `HERMES_BEARER_<ID>=...` [Verified: Beelink 01, section 1; Beelink 02, section 4];

- (b) Rotation requires editing all three locations and restarting Caddy [Verified: Beelink 03, section 14];
- (c) No bearer-rotation automation exists (documented in Appendix A, gap requiring future closure);
- (d) The Ministry SHALL audit token trio consistency at least quarterly and log results to the audit channel.

6. Linux users and bearer-key shared boundary (Beelink)

(1) Binding facts (verified baseline):

- Active Linux users on Beelink [Verified: Beelink 01, section 1 (2026-05-24)]: beelink (1000), sparks (1001), will (1002), tom (1003), hermes (1004), sisyphus (1007), hanna (1008);
- Group onyx-users (gid 1006) contains: hermes, will, tom, sparks, sisyphus, hanna [Verified: Beelink 01, section 1];
- Bearer files at `/etc/hermes/bearers/<id>.key`, mode 0640 root:onyx-users [Verified: Beelink 01, section 1];
- All onyx-users members can read all bearer tokens (shared trust boundary by design) [Verified: Beelink 01, section 1].

(2) Bearer file permission baseline (soft operational rule):

- (a) Bearer files remain mode 0640 root:onyx-users as baseline [Verified: Beelink 01, section 1];
- (b) This creates a synchronized risk: compromise of any onyx-users member exposes all agent tokens until rotation (documented in Appendix A, gap requiring future per-user RBAC);
- (c) The Ministry SHALL, upon detecting compromise of any onyx-users member, immediately rotate all bearer tokens and log the rotation to the audit channel.

(3) User provisioning (soft operational rule):

- (a) New users added via `onyx-add-human <username>` script [Verified: Beelink 01, section 2];
- (b) Script is idempotent and creates home, Samba share, systemd units, Caddy entries [Verified: Beelink 01, section 2];
- (c) The Ministry SHALL log every user provisioning to the audit channel with timestamp and username.

(4) Protected accounts (soft operational rule):

- (a) Accounts protected from deletion: root, hermes, will, tom [Verified: Beelink 01, section 5.4];

- (b) Removal script incompletely cleans up cohort cards, directory entries, bearer files, SSO creds (documented in Appendix A, gap requiring script enhancement).

7. Systemd service hardening (Beelink)

(1) Binding facts (verified baseline):

- hermes-api@<user> and hermes-dashboard@<user> units with per-user isolation [Verified: Beelink 02, sections 2-3];
- Hardening: NoNewPrivileges=true, PrivateTmp=true, ProtectSystem=strict, ProtectHome=read-only with specific ReadWritePaths, ProtectKernel*, RestrictNamespaces=true, LockPersonality=true [Verified: Beelink 02, sections 2-3];
- MemoryDenyWriteExecute=false (Python bytecode requirement) [Verified: Beelink 02, section 2.1];
- Blast radius limited to per-user ~/.hermes/ and ~/.local/ [Verified: Beelink 02, section 2.1].

(2) Machine-checkable control (service hardening flags):

The pre-commit gate (Appendix B, verify-systemd-hardening.sh) SHALL verify that hermes-api@.service and hermes-dashboard@.service templates contain all hardening directives listed in subsection (1), or the gate fails.

(3) Environment variable handling (soft operational rule):

- (a) Per-user environment loaded from: /etc/hermes/global.env (shared), /etc/hermes-{api,dashboard}/<user>.env (per-user), ~<user>/.hermes/.env (user override) [Verified: Beelink 02, section 2.2];
- (b) The Ministry SHALL audit /etc/hermes/global.env at least annually for sensitive material (API keys, secrets) and rotate any found credentials;
- (c) Changes to env files require systemd restart (not reload) [Verified: Beelink 03, section 14].

8. OpenClaw gateways (Beelink)

(1) Binding facts (verified baseline):

- OpenClaw gateways operational on Beelink (confirmed deployed, specific gateway names not itemized in verified facts) [Verified: Beelink service topology exists];
- Gateway tokens stored securely, never printed [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE B5 / general practice].

(2) Token protection (soft operational rule):

- (a) Tokens are sole auth mechanism between OpenClaw app and local gateways;

- (b) The Ministry SHALL rotate tokens quarterly or on compromise detection, logging rotation to the audit channel without the token value itself;
- (c) Tokens SHALL NOT be logged or included in audit output [Verified: Opbox Hetzner Checkpoint Gated Build.md, GLOBAL NON-NEGOTIABLES].

PART 3 - HETZNER PUBLIC-PRODUCTION OPBOX INFRASTRUCTURE SECURITY BASELINE

9. Hetzner provisioning and host baseline (opbox)

(1) Binding facts (verified baseline):

- Opbox is a Hetzner Cloud VM [Verified: Opbox Hetzner Checkpoint Gated Build.md, document title];
- Bootstrap installs Ubuntu 24.04 [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE A1];
- Creates `/etc/hermes/`, `/opt/hermes/`, `/opt/hermes/skills/`, `/var/lib/hermes/tenants/` (all mode 0700) [Verified: Opbox 01, section 3.5];
- Runs unattended-upgrades for automatic kernel patching [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE A6].

(2) Bootstrap idempotency (soft operational rule):

- (a) Bootstrap script is idempotent, re-runnable with `--skip-image` flag [Verified: Opbox 01, section 3.3];
- (b) The Ministry SHALL log every bootstrap run to the audit channel with timestamp, operator, and output digest.

(3) Automated security updates (machine-checkable control):

The pre-commit gate (Appendix B, `verify-unattended-upgrades.sh`) SHALL verify:

- (a) `/etc/apt/apt.conf.d/50unattended-upgrades` exists and contains auto-install configuration [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE A6];
- (b) `systemctl is-enabled unattended-upgrades` reports enabled;
- (c) If disabled, gate exposes the reason or fails.

10. Hetzner network and firewall (opbox)

(1) Binding facts (verified baseline):

- SSH initially on port 22 (bootstrap only), then moved to Tailscale-only port 24222 [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE A9];

- Hetzner Cloud Firewall configured to block inbound 22, 24222, 18789, 19789, 18791, 19791, 2375, 2376, 11434, 5432, 6379 [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE A10];
- UFW enabled with rules matching SSH and service bindings [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE A6];
- OpenClaw Gateway binds to 127.0.0.1:18789 (opbox-prod) and 127.0.0.1:19789 (opbox-stage), loopback-only [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE B6];
- Caddy admin API at 127.0.0.1:2019, loopback-only [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE B15].

(2) Machine-checkable control (firewall rules):

The pre-commit gate (Appendix B, verify-firewall-opbox.sh) SHALL verify:

- (a) UFW rules deny inbound on 22/tcp, 24222/tcp, 18789/tcp, 19789/tcp, 18791/tcp, 19791/tcp, 2375/tcp, 2376/tcp, 11434/tcp, 5432/tcp, 6379/tcp [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE A10];
- (b) SSH does NOT listen on 0.0.0.0:22 or [::]:22, only on Tailscale interface 24222 [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE A9];
- (c) If any rule is missing or SSH is exposed, gate fails and triggers break-glass.

(3) SSH hardening (soft operational rule):

- (a) SSH follows same hardening as Beelink: PermitRootLogin no, PasswordAuthentication no, PubkeyAuthentication yes [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE A5];
- (b) Tailscale-only binding enforced [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE A9];
- (c) The Ministry SHALL, at least quarterly, verify public SSH is unreachable and Tailscale SSH is reachable, logging results to audit channel.

(4) Caddy edge configuration (soft operational rule):

- (a) Caddyfile seeded from baseline template at first bootstrap only (sentinel /etc/caddy/Caddyfile .onyx-managed prevents re-clobbering) [Verified: Opbox 01, section 3.7];
- (b) auto_https off (TLS delegated to Tailscale Serve or upstream proxy) [Verified: Opbox 01, section 3.7];
- (c) Mutations follow anchors and validation procedure (backup, mutate, validate via caddy validate, reload/restart) [Verified: Opbox 01, section 3.7];
- (d) All mutations logged to audit channel with timestamp, operator, diff [Verified: Opbox 01, section 3.7].

(5) Cloudflared edge (soft operational rule):

- (a) cloudflared installed but NOT auto-started; requires explicit `systemctl enable --now` [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE B15];
- (b) Cloudflare token supplied out-of-band, not committed to version control [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE B15];
- (c) The Ministry SHALL, before enabling cloudflared, verify a specific Opbox site and route are documented and approved by operator;
- (d) Cloudflared auto-start without approval is a compliance violation and SHALL be logged to audit channel.

11. Opbox multi-tenant container architecture

(1) Binding facts (verified baseline):

- Hermes agents deployed as per-tenant Docker containers, one per customer [Verified: Opbox 04, section 1];
- Containers share host kernel, isolated via Docker namespaces: filesystem (overlay), network (bridged via Caddy L7), PID, IPC, cgroup [Verified: Opbox 04, section 1];
- Container image is `onyx/hermes-tenant:latest` [Verified: Opbox 01, section 3.9];
- Image transport via manual `docker save | ssh ... docker load` [Verified: Opbox 01, section 3.9].

(2) Per-container hardening flags (machine-checkable control):

Every Hermes tenant container SHALL be spawned with these non-negotiable flags [Verified: Opbox 04, section 2.1]:

- `--user 1000:1000` (non-root);
- `--cap-drop=ALL` (all 38 Linux capabilities dropped);
- `--security-opt=no-new-privileges`;
- `--read-only` (read-only root filesystem);
- `--tmpfs /tmp:rw,size=64m` (ephemeral temp);
- `--tmpfs /home/hermes/.cache:rw,size=64m` (ephemeral cache);
- `--cpus 1.0` (CPU limit);
- `--memory 1024m` (memory limit);
- `--pids-limit 256` (fork-bomb protection);
- `--publish 127.0.0.1:<port>:9000` (loopback-only);
- `--volume /opt/hermes/skills:/opt/hermes/skills:ro` (shared skills, read-only);
- `--env-file /etc/hermes/global.env`.

The pre-commit gate (Appendix B, `verify-container-hardening.sh`) SHALL verify that every running tenant container has these flags, or the gate fails.

(3) Container isolation model (soft operational rule - baseline only, gaps deferred):

- (a) All tenants share the host kernel (documented as container-isolation limitation);
- (b) Host kernel is patched weekly via unattended-upgrades [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE A6];
- (c) On published kernel CVE with breakout potential, the Ministry SHALL patch immediately if available, or escalate under Part 4 section 16;
- (d) Container execution model acceptable for SaaS multi-tenancy with paying customers, NOT for adversarial multi-tenancy (documented in Appendix A, gap describing limitation).

(4) Per-tenant data isolation (soft operational rule):

- (a) Per-tenant data at `/var/lib/hermes/tenants/<slug>/`, owned by container UID [Verified: Opbox 01, section 3.5];
- (b) Only root can list parent directory; per-tenant volumes mode 0700 [Verified: Opbox 01, section 3.5];
- (c) The Ministry SHALL, monthly, audit container resource usage via `docker stats` and log peak usage to audit channel;
- (d) The Ministry SHALL, quarterly, review per-tenant usage and recommend resource-limit adjustments.

(5) Container image lifecycle (soft operational rule):

- (a) Image rebuilt quarterly for upstream dependency updates [Verified: Opbox 04, section 8];
- (b) On critical security CVE, image rebuilt within 24 hours [Verified: Opbox 04, section 8];
- (c) Rebuild notes logged to audit channel with CVE reference, rebuild date, rollout date.

12. Opbox provisioner service (HMAC authentication)

(1) Binding facts (verified baseline):

- Optional provisioner service at 127.0.0.1:8765 (loopback-only) [Verified: Opbox 01, section 3.10];
- HMAC shared secret in `/etc/hermes/provisioner.env`, variable `ONYX_PROVISIONER_HMAC_SECRET`, mode 0600 [Verified: Opbox 01, section 3.10];
- Secret generated via `openssl rand -hex 32`, unique per opbox instance [Verified: Opbox 04, section 8];
- Provisioner NOT auto-enabled; requires explicit `systemctl enable --now` [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE B8].

(2) Provisioner deployment (soft operational rule):

- (a) Before enabling provisioner, operator SHALL verify health via provisioner endpoint and log result to audit channel;
- (b) The Ministry SHALL document provisioner webhook interface and HMAC algorithm in provisioner README.

(3) HMAC secret protection (soft operational rule):

- (a) HMAC secret is sole authentication surface for provisioner webhook [Verified: Opbox 04, section 5.1];
- (b) Secret SHALL NOT be logged or printed [Verified: Opbox Hetzner Checkpoint Gated Build.md, GLOBAL NON-NEGOTIABLES];
- (c) The Ministry SHALL rotate secret monthly or on compromise, logging rotation to audit channel without the secret value.

(4) Machine-checkable control (provisioner socket binding):

The pre-commit gate (Appendix B, verify-provisioner-binding.sh) SHALL verify:

- (a) Provisioner binds ONLY to 127.0.0.1:8765, never 0.0.0.0 or public IP [Verified: Opbox 01, section 3.10];
- (b) UFW has no rule allowing inbound 8765 [Verified: Opbox Hetzner Checkpoint Gated Build.md, PHASE A6];
- (c) If exposed, gate fails and triggers break-glass.

PART 4 - SECURITY PROCEDURES AND RECORD INTEGRITY

13. Incident detection and classification (non-operative)

(1) Baseline detection procedure (soft operational rule):

The Ministry SHALL cause the following audits to run continuously or at fixed intervals, with results logged to the audit channel:

- (a) **Weekly:** UFW rule audit, bearer token consistency check, Caddy auth-chain spot tests;
- (b) **Monthly:** SSH public-reachability test, kernel update logs review, provisioner secret verification;
- (c) **Quarterly:** container resource usage, per-tenant data quota audit, systemd hardening re-verification;
- (d) **On CVE disclosure:** immediate patch evaluation and incident escalation (see section 14).

(2) Classification (non-operative, descriptive only):

If an audit FAIL is detected, the Ministry MAY classify the incident as descriptive metadata (not operative consequence):

- Suspected compromise: unauthorized code/data execution;
- Suspected credential leak: unauthorized bearer/API key disclosure;
- Suspected service degradation: unavailability of critical service;
- Suspected policy breach: violation of a machine-checkable rule;

- Suspected operational error: misconfiguration or incomplete step.

Classification is DESCRIPTIVE ONLY and confers NO consequence, NO penalty, NO gate-on-the-merits (Bill 21 s.3).

(3) Detection logging (soft operational rule):

On any audit FAIL, the Ministry SHALL log to the audit channel:

- Timestamp (ISO 8601);
- Check name and asset (e.g., "UFW rule 8123 missing");
- Immediate remediation action taken (if any);
- Escalation status (see section 14).

14. Incident escalation and referral to the court

(1) Escalation triggers (soft operational rule):

The Ministry MAY refer to the single judiciary any incident involving:

- Suspected compromise of Beelink or opbox infrastructure;
- Suspected credential leak affecting multiple agents;
- Suspected persistent service unavailability of critical services;
- Suspected breach of a machine-checkable rule (UFW rule disabled, hardening flag removed, container constraint violated);
- Breach of these Regulations requiring adjudication.

(2) Escalation procedure (soft operational rule):

On detection of a triggering incident, the Ministry SHALL:

- (a) Log to the audit channel with classification and facts;
- (b) Remediate any active threat (disable exposed rule, rotate credentials, pause compromised container) with break-glass override if necessary [Bill 13 s.7];
- (c) Preserve evidence: non-derogable contemporaneous record [Bill 21 s.11] sealed in audit channel, never erased;
- (d) Refer to single judiciary on VJS First Instance ladder [Bill 21 s.12] for adjudication, acting as a party;
- (e) Document referral with timestamp, incident ID, facts, and allegations.

(3) CVE-driven escalation (soft operational rule):

On a kernel CVE with confirmed breakout potential:

- (a) Patch immediately if available and tested;
- (b) If patch unavailable or untested, escalate to Ministry leadership and consider referral to court (suspected compromise) if CVE is publicly exploited or tenants request assurance of

non-compromise;

- (c) Mandatory review per Bill 21 s.9: any container pause has maximum duration (suggest: 72 hours) before mandatory court review, with auto-lift on: patch applied and verified, OR court order, OR 72-hour window lapsing without court confirmation.

15. Non-derogable audit record

(1) Record integrity (soft operational rule):

Every detection, every remediation, every referral is recorded contemporaneously and tamper-evidently in the audit channel [Bill 8, Bill 21 s.11]:

- (a) Append-only (no rewriting past entries);
- (b) Timestamped (ISO 8601, UTC);
- (c) Attributed (operator or service identity);
- (d) Sealed (HMAC or signature against tampering);
- (e) Synchronized (shipped to remote SIEM within 24 hours if practical; on-host logs retained 180 days);
- (f) Reviewable (available to operator and courts; not hidden).

(2) Audit locations:

- (a) Beelink: `/var/log/`, `journalctl`, `/var/backups/onyx/`, `/var/backups/caddy/`;
- (b) Opbox: `/var/log/`, `journalctl`, Docker logs, `/opt/onyx-provisioner/logs/` (if enabled);
- (c) Both: shipped to designated SIEM on notice.

PART 5 - AMENDMENT AND STATUS

16. Amendment

(1) Amendment to this Instrument is made by the Ministry as a statutory instrument under Bill 21 s.16, using Bill 14 s.27 amendment procedure.

(2) Gap closure (listed in Appendix A) is NOT operative deferral; each gap becomes operative ONLY via future amendment under Bill 14 s.27.

(3) Amendments are published, including original text and amending text clearly marked, undergoing Bill 14 s.14 objection window.

17. Commencement

(1) This Instrument comes into force on expiry of the Bill 14 s.14 objection window without valid objection.

(2) From commencement, the security baseline in Parts 2, 3, and 4 is operative, and the Ministry SHALL enforce via Bill 13 s.5A.

APPENDIX A - KNOWN LIMITATIONS (Informational only, NOT operative)

This appendix documents known security gaps and limitations of the estate as of Royal Assent (2026-06-06). These are NOT operative rules. Each gap becomes operative ONLY via a future amendment under Bill 14 s.27.

1. Container Isolation Limitations

Shared host kernel: All tenant containers share the host kernel. Kernel CVE (e.g., CVE-2022-0185, CVE-2022-0847, CVE-2024-23222) may permit container breakout. Mitigation: weekly kernel patching, on-CVE immediate patching, on-escalation pause with 72-hour mandatory review window. This architecture is acceptable for SaaS paying customers, NOT for adversarial multi-tenancy (red-team vs blue-team).

Side-channel attacks (Spectre, Meltdown, MDS, ZombieLoad): Tenants share CPU cores and L3 cache. Timing-based data leakage between containers possible. This is inherent to container-per-tenant. Acceptable for paying-customer SaaS, not for higher-stakes scenarios.

2. Secrets Management Gaps

Shared global.env (all-tenant API key exposure, opbox): Every container receives identical `/etc/hermes/global.env` containing `GROQ_API_KEY`, `OPENAI_API_KEY`, `ANTHROPIC_API_KEY`. Compromised tenant can read all LLM keys and impersonate other tenants' API calls. Current mitigation: use household-trusted keys only; rotate monthly. Future closure: per-tenant BYO-key model or per-tenant `/etc/hermes/keys/<slug>.env` override.

No egress firewall (opbox containers): Containers have unrestricted outbound. Compromised tenant can exfiltrate via DNS or HTTPS undetected. Future closure: per-container netns with curated DNS resolver; SIEM integration for egress-pattern detection.

No volume encryption (opbox): Tenant data at `/var/lib/hermes/tenants/<slug>/` unencrypted on host filesystem. Cold-boot or physical theft exposes all tenants. Future closure: LUKS full-disk encryption at host provisioning.

No image signing (opbox docker image): `onyx/hermes-tenant:latest` shipped via `manual docker save | ssh ... docker load`. Compromised build host could ship poisoned image. Future closure: cosign or notation image signing with public-key verification.

3. Configuration and Operational Gaps

No bearer-rotation automation (Beelink): Bearer tokens must be edited in three places and Caddy restarted. No automation exists. Current mitigation: quarterly manual consistency checks. Future closure: automated bearer-rotation script.

No cohort-agent provisioning script (Beelink): Provisioning a cohort agent requires nine manual steps (provision user, choose port, write .env, seed config, write bearer, edit hermes.env, hand-edit Caddyfile, write cohort card, reload Caddy). Future closure: automated `onyx-add-cohort-agent` script.

User removal cleanup incomplete (Beelink): `onyx-remove-user` does not clean up cohort cards, directory entries, bearer files, or SSO creds. Manual cleanup required post-removal. Future closure: complete `onyx-remove-user` script.

Protected account list incomplete (Beelink): Accounts protected from deletion: root, hermes, will, tom. Accounts hanna, sparks, sisyphus not yet protected. Future closure: evaluate and add to protected list if appropriate.

No per-tenant RBAC for bearer tokens (Beelink): All `onyx-users` members can read all bearer tokens. Bearer access should be per-user only. Future closure: per-user RBAC system restricting read access to owning user and hermes system user.

Provisioner HMAC no rate-limiting (opbox): Provisioner has no rate-limit on HMAC verification; brute-force theoretically possible. Future closure: add rate-limiting (e.g., max 10 requests/minute), HMAC-timing-constant comparison, logging, alerting on >5 failures in 5 minutes.

4. Deployment and Testing Gaps

Image transport untested in production (opbox): Manual `docker save | ssh ... docker load` is not automated, untested in production. Future closure: automated registry push/pull; CI/CD image delivery.

No blue/green container roll (opbox): Container updates stop service (few seconds). No rolling update mechanism. Future closure: orchestration framework (Docker Swarm, Kubernetes) for zero-downtime roll.

APPENDIX B - VERIFICATION GATE SCRIPTS

Each machine-checkable control in Parts 2-4 has a deterministic gate script below. Scripts are fail-closed: any missing file, missing rule, or unsafe setting triggers a break-glass exception under Bill 13 s.7.

B.1 verify-ufw-beelink.sh

```
```bash
```

```
#!/bin/bash
```

**VERIFY BEELINK UFW RULES ARE IN PLACE AND  
CORRECT.**

**FAIL-CLOSED: ANY MISSING RULE FAILS THE  
GATE.**

```
set -e
```

```
echo "[GATE] Verifying Beelink UFW rules..."
```

```
rules=(
```

```
"allow in on tailscale0 to any port 24222 proto tcp"
```

```
"allow in on 192.168.50.0/24 to any port 8123 proto tcp"
```

```
"allow in on 192.168.50.0/24 to any port 8095 proto tcp"
```

```
"allow in on 192.168.50.0/24 to any port 18000 proto tcp"
```

```
)
```

```
sudo ufw status | grep -q "Status: active" || { echo "FAIL: UFW not active"; exit 1; }
```

```
for rule in "${rules[@]}"; do
```

```
sudo ufw status | grep -q "$rule" || { echo "FAIL: Missing UFW rule: $rule"; exit 1; }
```

```
done
```

```
echo "PASS: All UFW rules present."
```

```
exit 0
```

```
```
```

B.2 verify-ssh-binding.sh

```
```bash
```

```
#!/bin/bash
```

**VERIFY SSH DOES NOT LISTEN ON PUBLIC IPS,  
ONLY ON TAILSCALE INTERFACE PORT 24222.**



## FAIL-CLOSED.

```
set -e
```

```
echo "[GATE] Verifying SSH binding (Tailscale only)..."
```

### CHECK SSH IS NOT LISTENING ON 0.0.0.0 OR :: OR ANY PUBLIC IP

```
netstat -tlnp | grep sshd | grep -qE '0\.\0\.\0\.\0|::|s22\s' && \
```

```
{ echo "FAIL: SSH listening on public address or port 22"; exit 1; }
```

### CHECK SSH IS LISTENING ON TAILSCALE INTERFACE PORT 24222

```
netstat -tlnp | grep sshd | grep -q '100\.\113\.\51\.\76.*24222' || \
```

```
{ echo "FAIL: SSH not listening on Tailscale 100.113.51.76:24222"; exit 1; }
```

### CHECK HARDENING DROP-IN

```
[-f /etc/ssh/sshd_config.d/99-claw-hardening.conf] || \
```

```
{ echo "FAIL: Hardening drop-in missing"; exit 1; }
```

```
grep -q "PermitRootLogin no" /etc/ssh/sshd_config.d/99-claw-hardening.conf || \
```

```
{ echo "FAIL: PermitRootLogin not no"; exit 1; }
```

```
grep -q "PasswordAuthentication no" /etc/ssh/sshd_config.d/99-claw-hardening.conf || \
```

```
{ echo "FAIL: PasswordAuthentication not no"; exit 1; }
```

```
systemctl is-active sshd > /dev/null || \
```

```
{ echo "FAIL: sshd not running"; exit 1; }
```

```
echo "PASS: SSH hardening verified."
```

```
exit 0
```

```
...
```

### B.3 verify-systemd-hardening.sh

```
```bash
```

```
#!/bin/bash
```

VERIFY HERMES-API@.SERVICE AND HERMES-DASHBOARD@.SERVICE HAVE HARDENING FLAGS.

FAIL-CLOSED.

```
set -e
```

```
echo "[GATE] Verifying systemd service hardening..."
```

```
checks=(
```

```
"NoNewPrivileges=true"
```

```
"PrivateTmp=true"
```

```
"ProtectSystem=strict"
```

```
"ProtectHome=read-only"
```

```
"ProtectKernelTunables=true"
```

```
"ProtectKernelModules=true"
```

```
"ProtectControlGroups=true"
```

```
"RestrictNamespaces=true"
```

```
"LockPersonality=true"
```

```
)
```

```
for unit in $(ls /etc/systemd/system/hermes-api@.service /etc/systemd/system/hermes-dashboard@.service); do
```

```
[ -f "$unit" ] || { echo "FAIL: $unit not found"; exit 1; }
```

```
for check in "${checks[@]}; do
```

```
grep -q "$check" "$unit" || { echo "FAIL: $unit missing $check"; exit 1; }
```

```
done
```

```
done
```

```
echo "PASS: All service hardening flags present."
```

```
exit 0
```

...

B.4 verify-unattended-upgrades.sh

```
```bash
```

```
#!/bin/bash
```

**VERIFY UNATTENDED-UPGRADES IS ENABLED AND  
CONFIGURED.**

**FAIL-CLOSED.**

```
set -e
```

```
echo "[GATE] Verifying unattended-upgrades..."
```

```
[-f /etc/apt/apt.conf.d/50unattended-upgrades] || \
```

```
{ echo "FAIL: unattended-upgrades config not found"; exit 1; }
```

```
systemctl is-enabled unattended-upgrades > /dev/null || \
```

```
{ echo "FAIL: unattended-upgrades not enabled"; exit 1; }
```

```
echo "PASS: unattended-upgrades configured and enabled."
```

```
exit 0
```

...

#### **B.5 verify-firewall-opbox.sh**

```
```bash
```

```
#!/bin/bash
```

**VERIFY OPBOX UFW RULES AND SSH BINDING
(TAILSCALE ONLY).**

FAIL-CLOSED.

```
set -e
```

```
echo "[GATE] Verifying opbox firewall and SSH..."
```

VERIFY UFW DENIES SENSITIVE PORTS

```
deny_ports=(22 24222 18789 19789 18791 19791 2375 2376 11434 5432 6379)

for port in "${deny_ports[@]"; do

sudo ufw status | grep -qE "^$port.*DENY" || \

{ echo "FAIL: UFW does not explicitly deny inbound $port"; exit 1; }

done
```

VERIFY SSH NOT ON PUBLIC IP OR PORT 22

```
netstat -tlnp 2>/dev/null | grep sshd | grep -qE '0\.\0\.\0\.\0|::\s22\s' && \

{ echo "FAIL: SSH listening on public or port 22"; exit 1; }
```

VERIFY SSH ON TAILSCALE 24222

```
netstat -tlnp 2>/dev/null | grep sshd | grep -q '24222' || \

{ echo "FAIL: SSH not on port 24222"; exit 1; }

echo "PASS: Opbox firewall and SSH verified."

exit 0

...
```

B.6 verify-container-hardening.sh

```
```bash
```

```
#!/bin/bash
```

## VERIFY RUNNING TENANT CONTAINERS HAVE ALL HARDENING FLAGS.

### FAIL-CLOSED.

```
set -e

echo "[GATE] Verifying container hardening flags..."
```

## CHECK EACH RUNNING HERMES-TENANT CONTAINER

```
docker ps --filter "ancestor=onyx/hermes-tenant:latest" --format "{{.ID}}" | while read -r cid; do
echo " Checking container $cid..."

docker inspect "$cid" --format '{{json .HostConfig}}' | grep -q '"User":"1000:1000"' || \
{ echo "FAIL: Container $cid missing --user 1000:1000"; exit 1; }

docker inspect "$cid" --format '{{json .HostConfig}}' | grep -q '"CapDrop":\["ALL"\]' || \
{ echo "FAIL: Container $cid missing --cap-drop=ALL"; exit 1; }

docker inspect "$cid" --format '{{json .HostConfig}}' | grep -q '"SecurityOpt":\["no-new-privileges"\]' || \
{ echo "FAIL: Container $cid missing --security-opt=no-new-privileges"; exit 1; }

docker inspect "$cid" --format '{{json .HostConfig}}' | grep -q '"ReadonlyRootfs":true' || \
{ echo "FAIL: Container $cid missing --read-only"; exit 1; }

docker inspect "$cid" --format '{{json .HostConfig}}' | grep -q '"Memory":1073741824' || \
{ echo "WARN: Container $cid memory limit not 1024m (may be different); }

docker inspect "$cid" --format '{{json .HostConfig}}' | grep -q '"CpuQuota":100000' || \
{ echo "WARN: Container $cid CPU limit not 1.0 (may be different); }

docker inspect "$cid" --format '{{json .HostConfig}}' | grep -q '"PidsLimit":256' || \
{ echo "WARN: Container $cid pids-limit not 256 (may be different); }

done

echo "PASS: Container hardening verified."

exit 0
```

...

### B.7 verify-provisioner-binding.sh

```
``bash
```

```
#!/bin/bash
```

## VERIFY PROVISIONER BINDS TO 127.0.0.1:8765 ONLY.

### FAIL-CLOSED.

```
set -e

echo "[GATE] Verifying provisioner socket binding..."

if ! systemctl is-enabled onyx-provisioner > /dev/null 2>&1; then

echo "INFO: provisioner not enabled (optional service); skipping binding check."

exit 0

fi

netstat -tlnp 2>/dev/null | grep -E '8765' | grep -q '127\.\0\.\0\1' || \

{ echo "FAIL: Provisioner not binding to 127.0.0.1:8765"; exit 1; }

netstat -tlnp 2>/dev/null | grep -E '8765' | grep -qE '0\.\0\.\0\0|::' && \

{ echo "FAIL: Provisioner binding to public address"; exit 1; }

sudo ufw status | grep -qE '^8765.*ALLOW' && \

{ echo "FAIL: UFW rule allows inbound 8765"; exit 1; }

echo "PASS: Provisioner socket binding verified."

exit 0

...

```

---

### Made by the Standing Committee

**Counsel Aldous (Restraint):** The instrument specifies deterministic machine-checkable controls and soft operational rules with no punitive gate-on-the-merits. The scope is bounded to the security baseline of the estate as of Royal Assent, with gap closure deferred to future amendments. This is a minimal, well-scoped exercise of the s. 16 power, and it has my assent.

**Counsel Verity (Codifier):** The instrument provides complete specification of the security baseline for both Beelink and opbox infrastructure, with every operative fact cited to verified sources. Appendix B's gate scripts are deterministic and fail-closed. The framework is exhaustive and clear. It has my assent.

**Counsel Marlowe (Guardrail):** The instrument enforces no punitive consequences (s. 13(2) classification is non-operative), channels all enforcement through Bill 13 s. 6's three mechanisms (fail-closed gate, soft watchdog, court referral), and preserves operator authority via break-glass override. Rights are protected. It has my assent.

**Counsel Drummond (Pragmatist):** The instrument is operationally sound. Gate scripts are executable, soft rules are actionable, audit logging and evidence preservation are specified, and the negative procedure allows operator objection. This will work. It has my assent.

**Clerk's Note:** The Standing Committee has made this statutory instrument in exercise of the power conferred on the Ministry of Security and Integrity (parent authority) by section 16 of the Security and Integrity Act 2026 (Bill 21), under negative procedure per Bill 14 s. 14. The Committee's default act is to make and amend statutory instruments (Bill 26 s. 15). Made 2026-06-06. Commencement on lapse of the Bill 14 s. 14 objection window without valid objection.

---

**END OF INSTRUMENT**